

Senhas e chaveiros

incremente sua segurança

Vitor Mattos

Fotografem, comentem, twitterem!

@VitorMattosRj



Olá! Estava no Rio Agile?

Sim, foi show! Aliá, achei a sua apresentação a melhor. Parabéns!

Não conhecia a ferramenta até então, eu estava iniciando ainda meus estudos sobre BDD. Achei a palestra muito boa mesmo meu nível no assunto sendo muito introdutório.

que trampo foda mano, mt obrg por compartilhar esse conhecimento bro! ou mostrar isso pros devs, talvez isso ajude a engajar os caras a mudar.

Hoje tive a oportunidade de ouvir este grande cara [@VitorMattos](#)
Deixo aqui os meus parabéns, foi uma grande palestra, valeu cada minuto e espero ver mais o seu trabalho fera, parabéns !

22:46

Gostei muito da sua palestra, eu que sou iniciante não entendia bem a importância do composer, ficou muito claro que ele é muito útil e como implementar, adorei.

Obrigado por compartilhar esse tão precioso conhecimento conosco.

Nota 10!!! 🍌🍌🍌🍌🍌

12:49

Quem sou eu?

Desenvolvedor PHP desde 2003

Amante de opensource

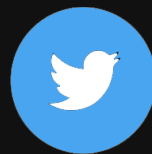
Evangelista PHP

PHP Zend Certified Engineer ([ZEND024235](#))

PHPRio (<https://telegram.me/phprio>)

CTO Lyseon Tech

Redes sociais: (VitorMattos ou VitorMattosRJ)





LYSEONTECH

A Lyseon Tech é uma cooperativa de trabalho com modelo de gestão democrática, segura e eficiente composta por profissionais de T.I. altamente qualificados e experientes no mercado. Prezamos por apresentar vantagens, tanto para o cooperado como para as empresas parceiras.

Cronograma

Tentarei ser breve :-D

- Introdução / definições
- Aplicações web
 - hash
 - oAuth
 - 2FA
- Políticas de senhas
- Criando senhas
- Chaveiros de senhas
 - KeePass

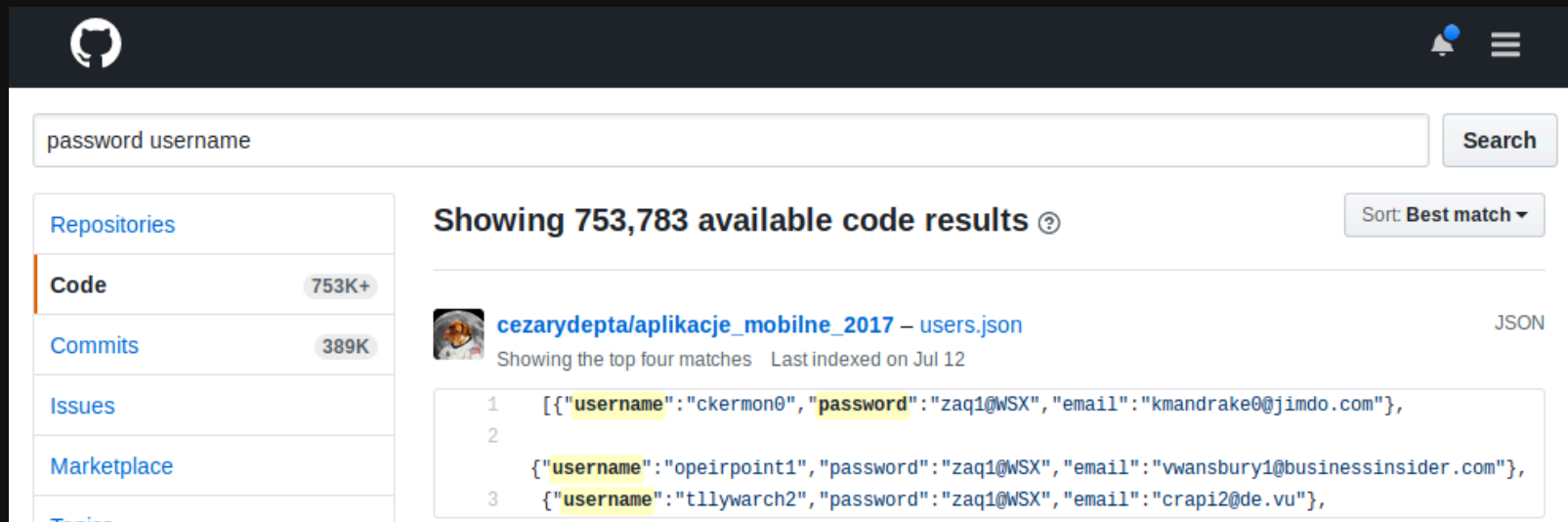
O que é uma senha?

Password

O que é secreto?



Dados sensíveis



The screenshot shows a GitHub search interface. At the top, the GitHub logo is on the left, and a notification bell and menu icon are on the right. Below the header is a search bar containing the text 'password username' and a 'Search' button. On the left side, there is a sidebar with navigation links: 'Repositories', 'Code' (highlighted with an orange bar and showing '753K+'), 'Commits' (showing '389K'), 'Issues', 'Marketplace', and 'Topics'. The main content area displays the search results. It starts with the text 'Showing 753,783 available code results' followed by a help icon. To the right of this text is a 'Sort: Best match' dropdown menu. Below this, a repository entry is shown: 'cezarydepta/aplikacje_mobilne_2017 – users.json' with a JSON file icon. Underneath the repository name, it says 'Showing the top four matches' and 'Last indexed on Jul 12'. A code block displays the top four matches, which are JSON objects containing sensitive data like usernames, passwords, and emails. The code is numbered 1 through 3, with the fourth match being truncated.

password username **Search**

[Repositories](#)

Code 753K+

[Commits](#) 389K

[Issues](#)

[Marketplace](#)

[Topics](#)

Showing 753,783 available code results ?

Sort: **Best match** ▾

 [cezarydepta/aplikacje_mobilne_2017](#) – users.json JSON

Showing the top four matches Last indexed on Jul 12

```
1 [{"username": "ckerm0n0", "password": "zaq1@WSX", "email": "kmandrake0@jimdo.com"},
2
3 [{"username": "opeirpoint1", "password": "zaq1@WSX", "email": "vwansbury1@businessinsider.com"},
4 [{"username": "tllwarch2", "password": "zaq1@WSX", "email": "crap12@de.vu"},
```

Dados sensíveis

Não versione!

Packagist 

vlucas/phpdotenv

 `composer require vlucas/phpdotenv`

Loads environment variables from ``.env`` to ``getenv()``, ``$_ENV`` and ``$_SERVER`` automagically.

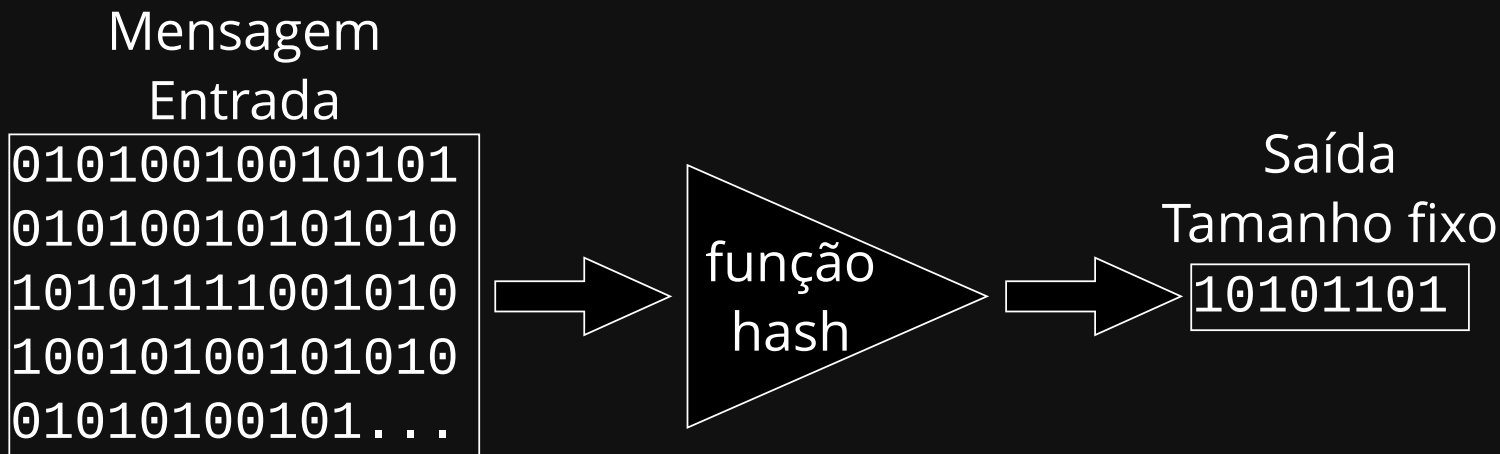
Aplicações web

Segurança de aplicações web

Vitor Mattos

Armazenamento: hash

Definição: *"transformação de uma grande quantidade de dados em uma pequena quantidade de informações"*



Função de mão única

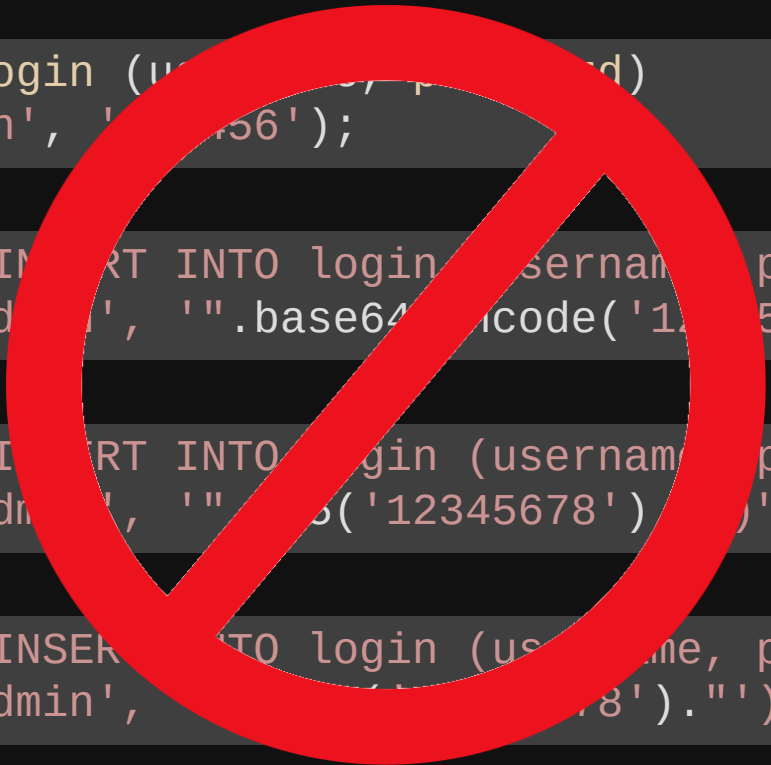
plain/text, base64, md5, sha1

```
INSERT INTO login (username, password)  
VALUES ('admin', '123456');
```

```
mysql_query("INSERT INTO login (username, password)  
VALUES ('admin', '".base64_encode('12345678')."')");
```

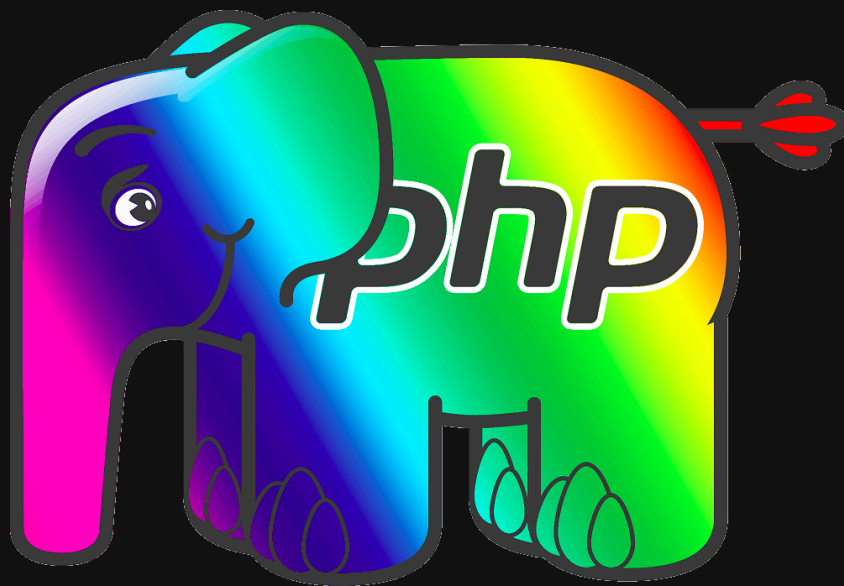
```
mysql_query("INSERT INTO login (username, password)  
VALUES ('admin', 'md5('12345678')')");
```

```
mysql_query("INSERT INTO login (username, password)  
VALUES ('admin', 'sha1('12345678')."')");
```



Rainbow Table

Definição: *"Uma **rainbow table** é uma tabela de consulta de hashes pré calculados."*



Evitando Rainbow Table

Evitando Rainbow Table



e10adc3949ba59abbe56e057f20f883e 

Web Images Videos News

☐ Brazil ▼ Safe Search: Off ▼ Any Time ▼

MD5 Password lookup e10adc3949ba59abbe56e057f20f883e by ...
Password Decoder Provided by HAQ 4 U.com e10adc3949ba59abbe56e057f20f883e reverse
MD5 is 123456 reverse MD5 is 123456

 e10adc3949ba59abbe56e057f20f883e.haq4u.com

MD5(123456) = e10adc3949ba59abbe56e057f20f883e :: Generat...
MD5("123456") = e10adc3949ba59abbe56e057f20f883e SHA1("123456") =
7c4a8d09ca3762af61e59520943dc26494f8941b SHA224("123456" ...
 <https://tool-bar.appspot.com/hash?input=123456>

password_hash

Criando hash

```
php > for($i=1;$i<=3;$i++)  
php > echo password_hash("Vitor Mattos", PASSWORD_DEFAULT)."\n"  
$2y$10$iDT0scwr0cP28mb.J0edv0KmmHdGfonvQcnr lQnc6M0BIUoZQ/waW  
$2y$10$Dmfc8Dc9ohV2lKn0jk5IxeHCos6AayVx/vvgz78MuIy9KaxVKuChe  
$2y$10$rVlAfjB3CX8ZmwjCT8boL.Wi8pFMsUZzTkA5XDSsTNbzBa2vvZ3xC
```

Validando hash

```
var_dump(password_verify(  
    "Vitor Mattos",  
    "$2y$10$Dmfc8Dc9ohV2lKn0jk5IxeHCos6AayVx/vvgz78MuIy9KaxVKuChe  
));  
  
true
```

Corrigindo o problema

```
if ($hash == md5($_POST['password'])) {  
    $hash = password_hash(  
        $_POST['password'],  
        PASSWORD_DEFAULT  
    );  
    $db->exec(  
        "UPDATE login SET password = ? WHERE user = ?"  
    );  
}
```

Bruteforce



hashcat is the world's fastest and most advanced password recovery tool.

This version combines the previous CPU-based hashcat (now called **hashcat-legacy**) and GPU-based **oclHashcat**.

Hashcat is **released** as open source software under the **MIT** license.

Cluster GPU



25 GPUs
brute force
348 billion
hashes per
second to
crack your
passwords

Cálculo de complexidade

Entropia: *"média de informação transmitida por um evento, quando se considera todos os resultados possíveis"*

Password length:

Speed: passwords per second

Number of computers:

☒ chars in lower case	☒ common punctuation
☒ chars in upper case	☒ full ASCII
☒ digits	

Calculate!

Brute Force Attack will take up to 7 hours

<https://github.com/vitormattos/crack-password-calc>

Bruteforce

□□□□□□□□□□□□□□ PALAVRA-BASE INCOMUM ORDEM DESCONHECIDA Tr0v4dor &3 CAPS? NUMERAL □□□ □□□□ (PODE COLOCAR MAIS UNS BITS PARA COMPENSAR O FATO DE QUE ESSE É APENAS UM DENTRE ALGUNS FORMATOS COMUNS)	~28 BITS DE ENTROPIA □□□□□□□□ □□□□□□□□ □□□□ □□□□ $2^{28} = 3 \text{ DIAS}$ COM 1000 TENTATIVAS/SEGUNDO (ATAQUE PLAUSIVEL EM UM SITE WEB, FRÁGIL. QUEBRAR HASHS ROUBADOS É MAIS RÁPIDO, MAS NÃO É COM O QUE O USUÁRIO COMUM SE PREOCUPA) DIFICULDADE DE QUEBRAR: FÁCIL	ERA TROCADOR? NÃO, ERA TROVADOR. E UM DOS 0s ERA ZERO? E TINHA AQUELE SÍMBOLO...  DIFICULDADE DE LEMBRAR: DIFÍCIL
<i>correto</i> <i>burro</i> <i>grampo</i> <i>bateria</i> □□□□□ □□□□□ □□□□□ □□□□□ □□□□□ □□□□□ □□□□□ □□□□□ QUATRO PALAVRAS ALEATÓRIAS COMUNS	~44 BITS DE ENTROPIA □□□□□□□□□□ □□□□□□□□□□ □□□□□□□□□□ □□□□□□□□□□ $2^{44} = 550 \text{ ANOS}$ COM 1000 TENTATIVAS/SEGUNDO DIFICULDADE DE QUEBRAR: DIFÍCIL	UM GRAMPO DE BATERIA! CORRETO!  DIFICULDADE DE LEMBRAR: VOCÊ JÁ MEMORIZOU

DEPOIS DE 20 ANOS DE ESFORÇO NÓS CONSEGUIMOS EFETIVAMENTE TREINAR TODO MUNDO A USAR SENHAS QUE SÃO DIFÍCEIS PARA OS HUMANOS MEMORIZAREM, MAS FÁCEIS PARA OS COMPUTADORES ADIVINHAREM..

Bruteforce

Senhas complexas e pequenas só são difíceis de decorar, mas continuam sendo simples de quebrar.

Resolvendo o problema de
bruteforce em aplicações web ...

Segurança de
aplicações web
Vitor Mattos

oAuth



OAuth

Segurança



*"Facebook hackeado:
ataque atinge 50
milhões de usuários"*

2018-09-28

OAuth

Privacidade



2FA, 3FA, 4FA, ..., nFA



2FA, 3FA, 4FA, ..., nFA

Quem aceita?

<https://twofactorauth.org/>



Two Factor Auth (2FA)

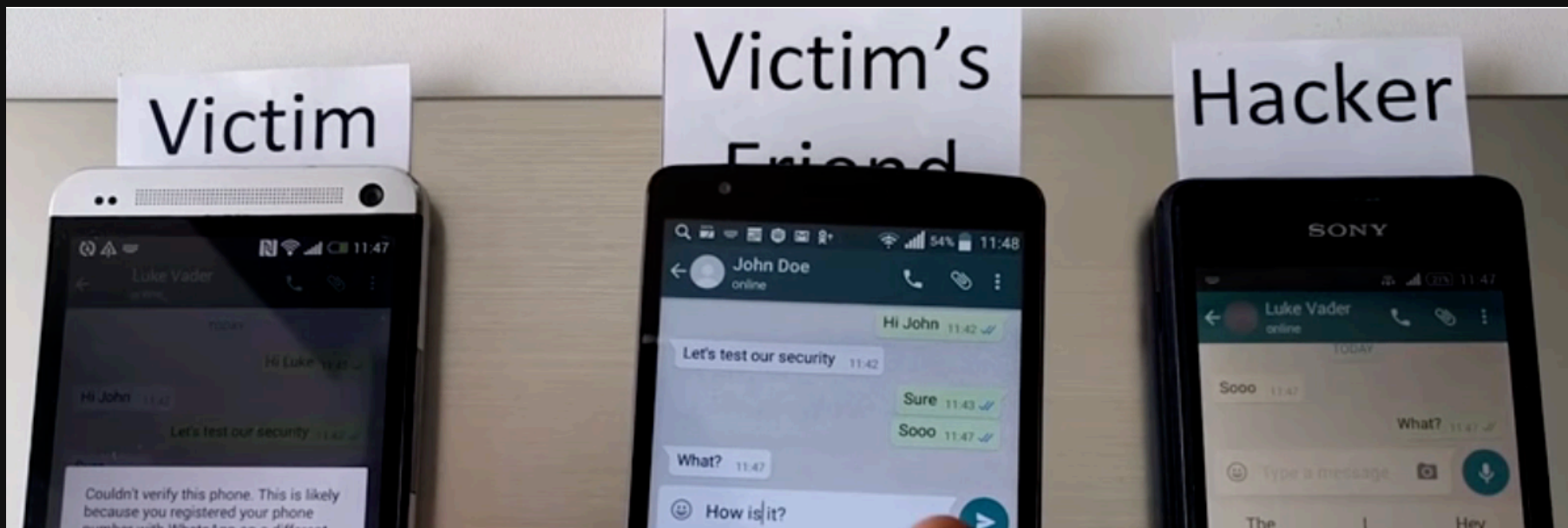
List of websites and whether or not they support [2FA](#).

Add your own favorite site by submitting a pull request on the [GitHub repo](#).



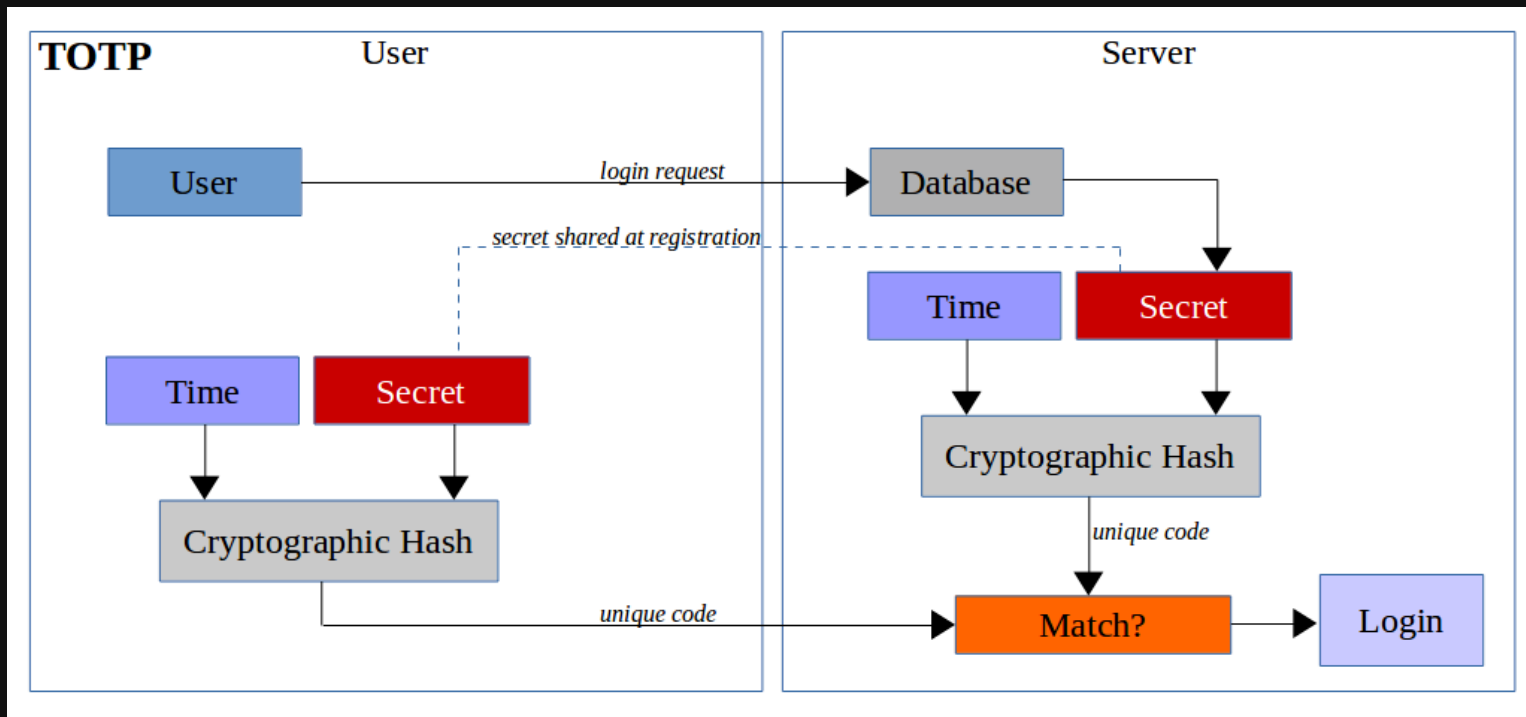
2FA, 3FA, 4FA, ..., nFA

Token SMS



2FA, 3FA, 4FA, ..., nFA

TOTP, o que é?



2FA, 3FA, 4FA, ..., nFA

Hardware de TOTP

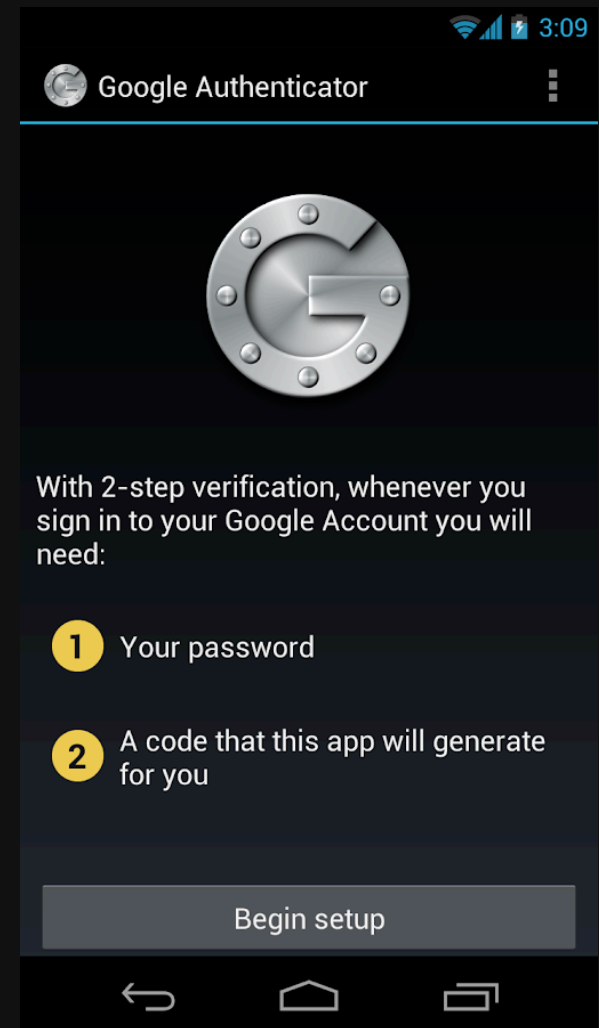


2FA, 3FA, 4FA, ..., nFA

Hardware de TOTP: riscos



2FA, 3FA, 4FA, ..., nFA TOTP no celular



2FA, 3FA, 4FA, ..., nFA

TOTP no celular: riscos



Prefira sempre HTTPS

HTTP vs HTTPS



Política de senhas



Política de senhas

Desculpe, sua senha deve conter uma letra maiúscula, dois números, um símbolo, uma mensagem inspiradora, um feitiço, um sinal de gangue, um hieróglifo e o sangue de uma virgem.



We Know Memes

Política de senhas

Limite máximo



Criando senhas

Vazamento



Criando senhas

Vazamento: senhas comuns



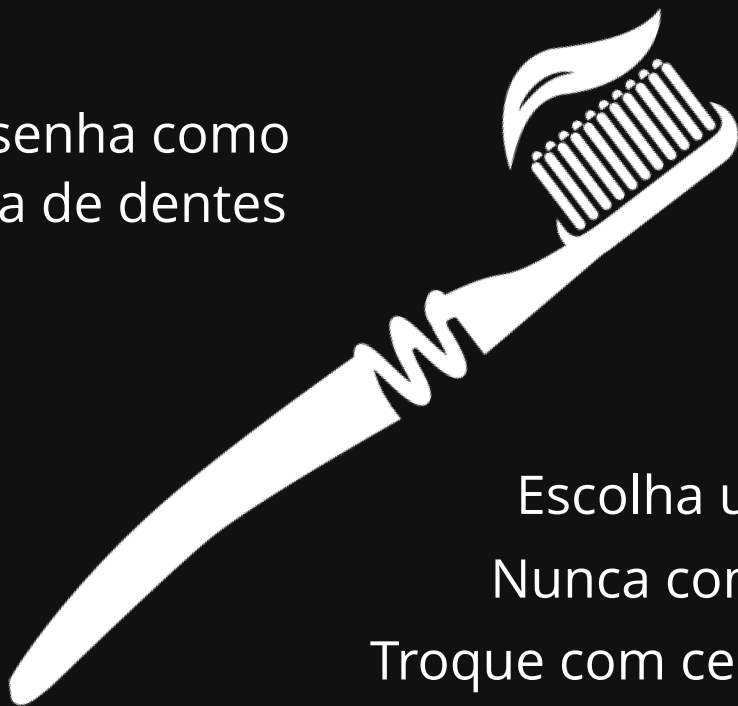
Criando senhas

Vazamento: toda senha deve ser forte



Criando senhas

trate sua senha como
sua escova de dentes



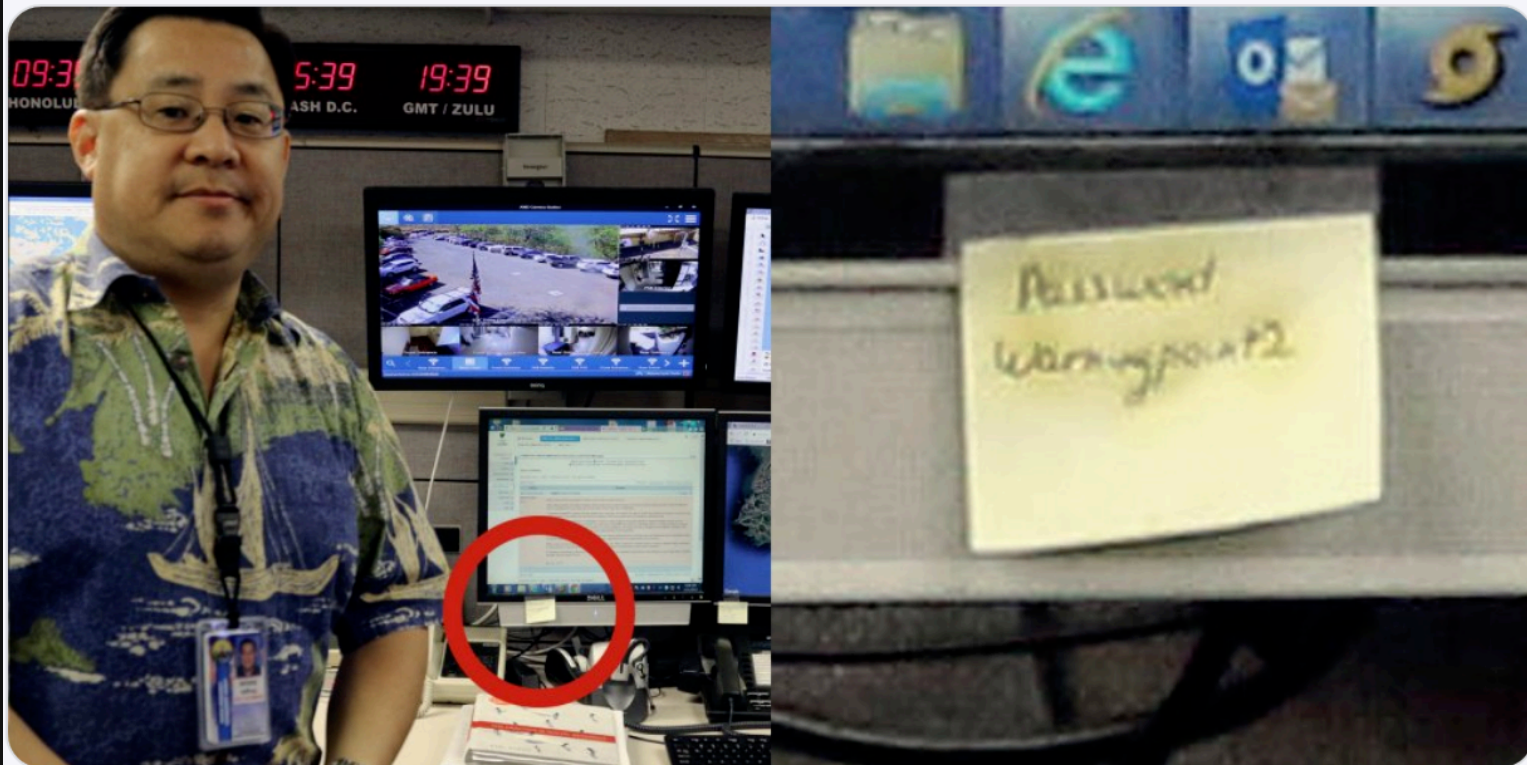
Escolha uma boa
Nunca compartilhe
Troque com certa frequência

Criando senhas

Evite:

- informações pessoais
- redes sociais revelam senhas
- observadores

A **password** for the **Hawaii** emergency agency was hiding in a public photo, written on a **post-it** note read.bi/2DB4RRz



19 166 229

Criando senhas

Evite: salvar em arquivos abertos

`/*/senhas.txt`

`/*/password.txt`

`/*/senhas.xlsx`

Criando senhas

Faça:

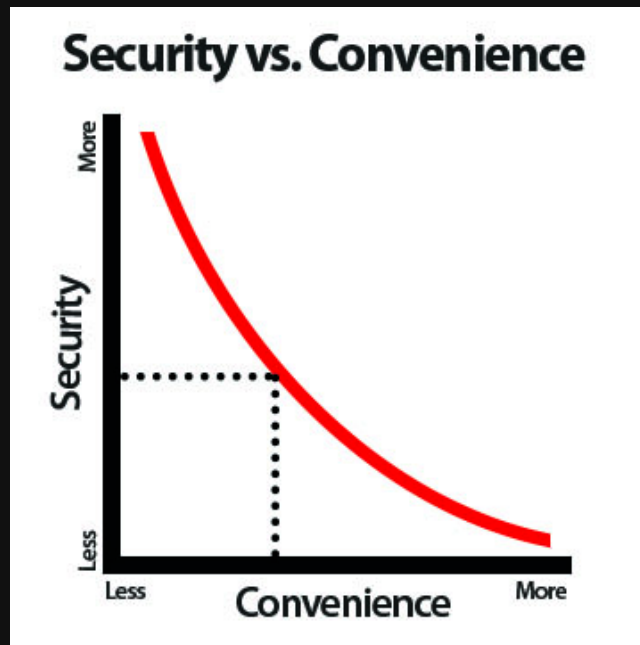
- passphrase
- senhas únicas
- caracteres especiais e aleatórios
- distribuição de proporcional de caracteres
- senhas longas
- mude se alguém criou

Senhas geradas por humanos

- baixa entropia
- Memória humana falha



Segurança x Conveniência



Chaveiros de senhas:

O que são?



Chaveiros de senhas: porque usar?

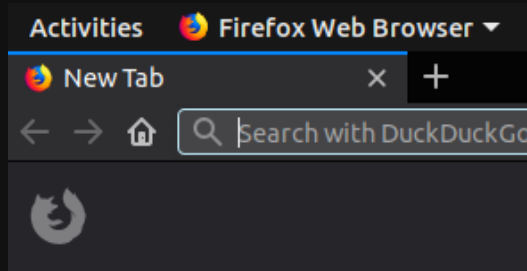
Senhas grandes - entropia

Senhas únicas

Não perder senhas

Ocupar a mente com o que é importante

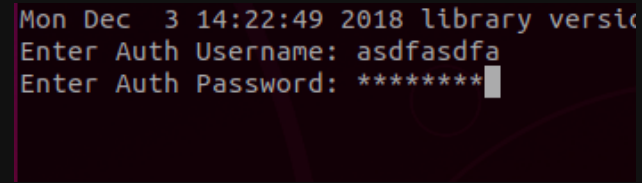
Onde usar?



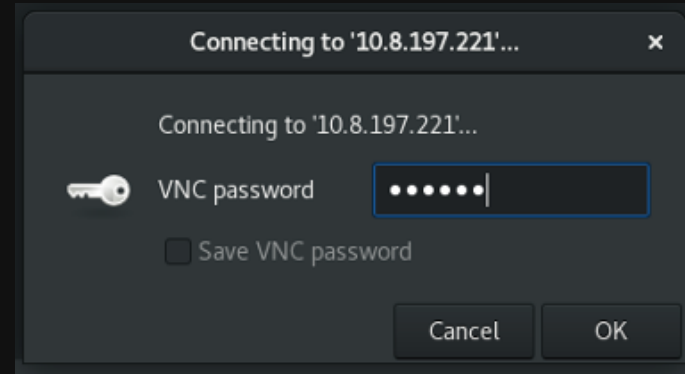
Navegadores



Celular



Terminal



Aplicações desktop

Chaveiros de senhas:

Riscos: Salvar no navegador

- Nem sempre se tem backup
- Extensões maliciosas
- Alguém pode usar seu pc

Chaveiros de senhas:

Riscos: Chaveiro na nuvem

lifehacker | VIDEO SKILLET TWO CENTS VITALS OFFSPRING THE UPGRADE APP DIRECTORY

LastPass Hacked, Change Your Master Password Now

 Eric Ravenscraft
6/15/15 3:30pm • Filed to: HACKED ▾

 297.5K  250  16



Chaveiros de senhas:

Riscos: Terceiros guardarem suas senhas

Google e outros serviços de chaveiro online proprietários



OpenSource



4 liberdades do software livre

Liberdade nº 0: A liberdade para executar o programa, para qualquer propósito;

Liberdade nº 1: A liberdade de estudar como o programa funciona, e adaptá-lo para as suas necessidades. Acesso ao código-fonte é um pré-requisito para esta liberdade;

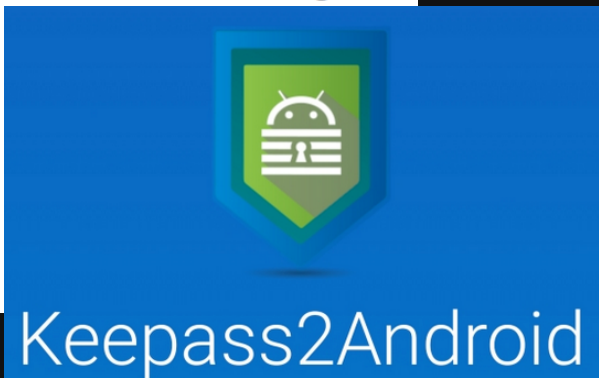
Liberdade nº 2: A liberdade de redistribuir de forma que você possa ajudar o seu próximo;

Liberdade nº 3: A liberdade de modificar o programa, e liberar estas modificações, de modo que toda a comunidade se beneficie. Acesso ao código-fonte é um pré-requisito para esta liberdade;

Chaveiros livres: KeePass



KeePass Touch 4+
The Password Manager



Keepass2Android



KeePass



KEEPASSXC

KeePassX

Cross Platform Password Manager

Cientes

KeePass



Primeira versão livre

Escrito em .NET

É multiplataforma.

Funciona em sistemas Linux mas precisa do Mono, fica meio feio

Clientes

KeePassX



Como o nome já diz, cross platform.

Problema: o projeto está meio abandonado, o mantenedor não aceita Pull Request faz um tempo

Cientes

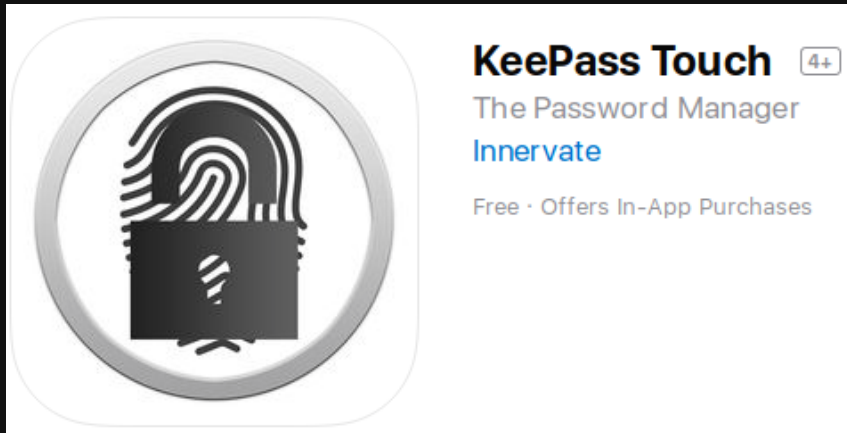
KeePassXC



Um fork do KeePassX...

Só que mantido pela comunidade, este aceita PR e é um projeto bem ativo.

Cientes Celular

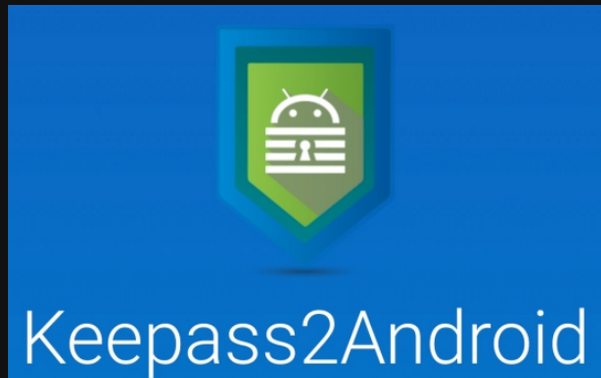


Para iPhone, nunca
usei, nem quero usar.



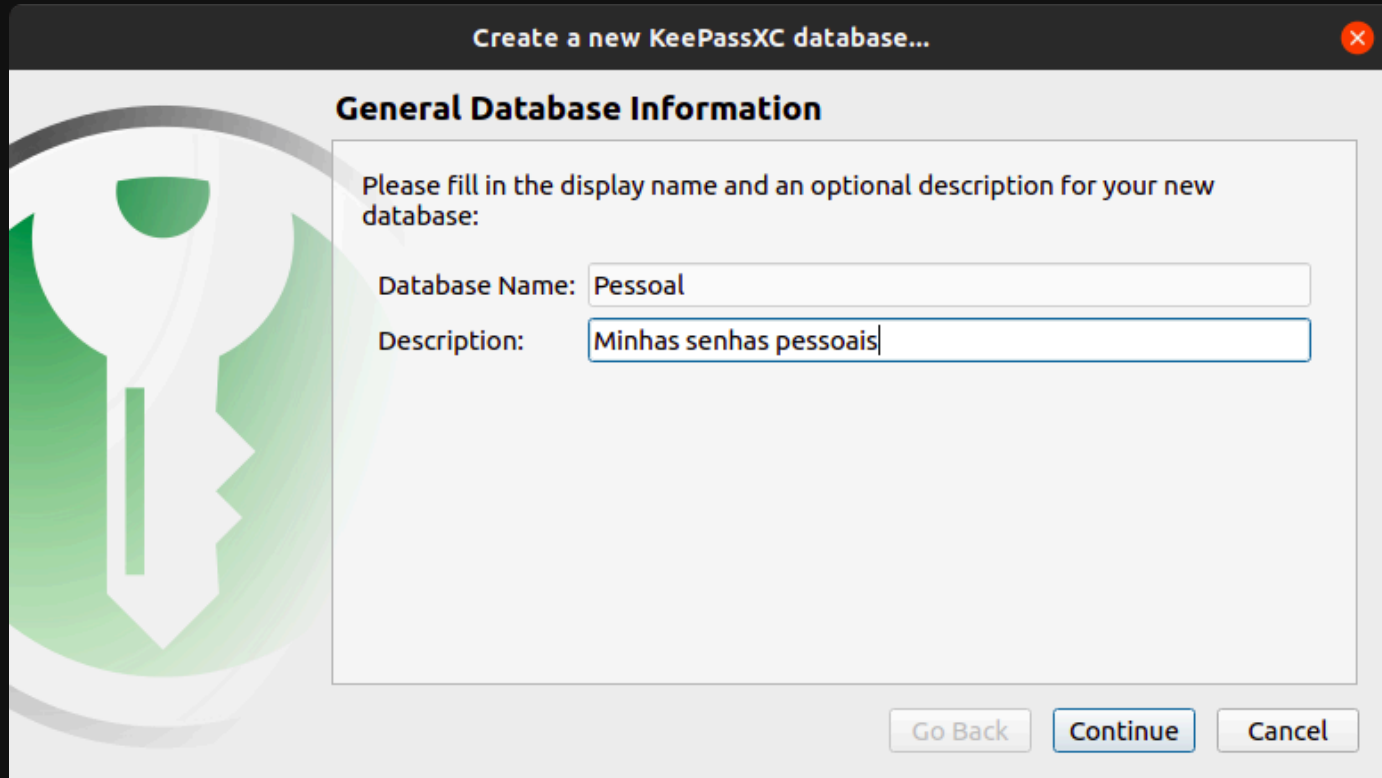
Cientes

Celular



- Interface bem amigável
- Teclado exclusivo (facilita muito)
- Aceita plugins
- Desbloqueio biométrico (nunca testei)
- Sincronismo da base de dados com vários lugares diferentes
- Pode abrir várias bases de dados simultaneamente
- Autocomplete (Android >= 8)

Criando o primeiro chaveiro



Create a new KeePassXC database...

General Database Information

Please fill in the display name and an optional description for your new database:

Database Name:

Description:

Criando o primeiro chaveiro





Database Master Key

A master key known only to you protects your database.

Password

Enter password: Uma grande \$enha bem \$egura aqui ajuda mto.



Confirm password: Uma grande \$enha bem \$egura aqui ajuda mto.



Cancel

Key File

You can add a key file containing random bytes for additional security.

You must keep it secret and never lose it or you will be locked out!

Add Key File

YubiKey Challenge-Response

If you own a [YubiKey](#), you can use it for additional security.

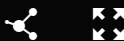
The YubiKey requires one of its slots to be programmed as [HMAC-SHA1 Challenge-Response](#).

Add YubiKey Challenge-Response

Go Back

Done

Cancel



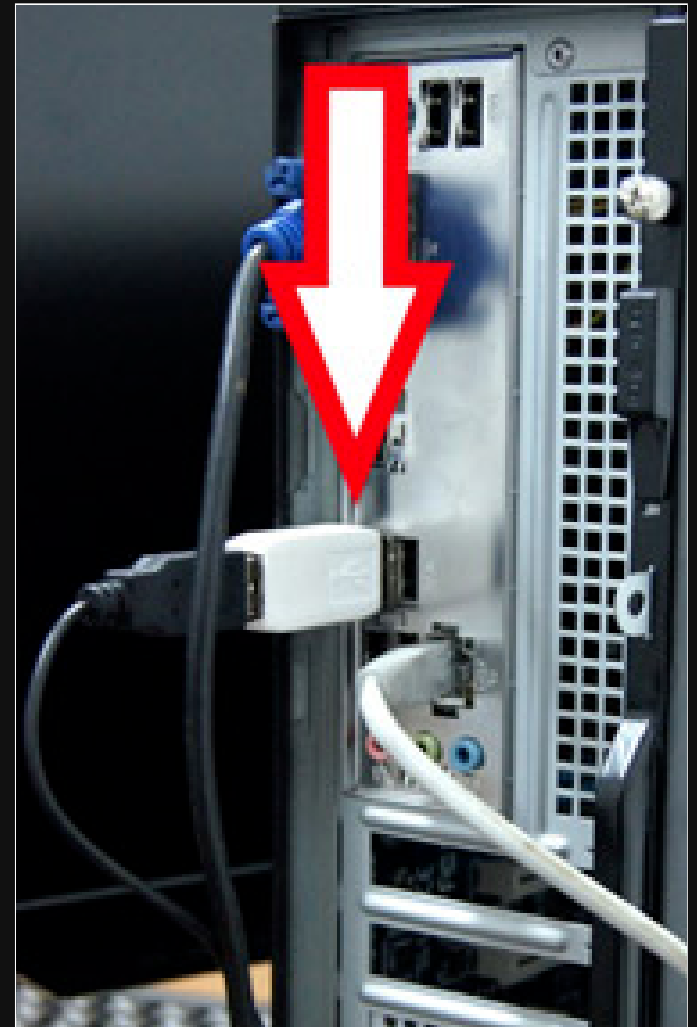
Senha mestre

- Troque de vez em quando
- Esta deve ser complexa
- Multifator
- Bloquear chaveiro ao bloquear máquina
- Cuidado com pessoas observando
- Não confie em sua memória, tenha alguém de confiança para backup da senha

Senha mestre

Use em computadores
seguros:

Keyloggers



Onde salvar?

Sincronismo



Criando a base de dados

Diferentes bases para diferentes fins

- Clientes
 - Empresa A
 - Empresa B
- Pessoas
- Outras pessoas

Novo registro

O que salvar no
chaveiro?

- Senhas (dãããhh)
- Dados de documentos
- Dados de cartões
- Anotações secretas diversas
- Chaves de SSH
- Outras chaves de autenticação
- Mapa do tesouro

Novo registro

Geração de senhas

Password: 

Password Quality: Excellent Entropy: 1926.09 bit

Length:

Character Types

A-Z	0-9	.,;	<input type="button" value("<*&#x21;?=""/>	<input type="button" value("#\$%&@^`~"=""/>	Simple
a-z	<input type="button" value("[{(""=""/>	<input type="button" value("'"=""/>	<input "="" data-bbox="786 757 899 797" type="button" value("\ _=""/>	ExtendedASCII	

Do not include:

☒ Exclude look-alike characters

☒ Pick characters from every group

Novo registro

Campos extras

Additional attributes

CVV

Expire

Expire month

Expire year

First name

Last Name

Name

Number

[PROTECTED] Press reveal to view or edit

Add

Remove

Edit Name

☒ Protect

Reveal

Attachments

Name	Size
vitor.pem	1,87 KiB

Add

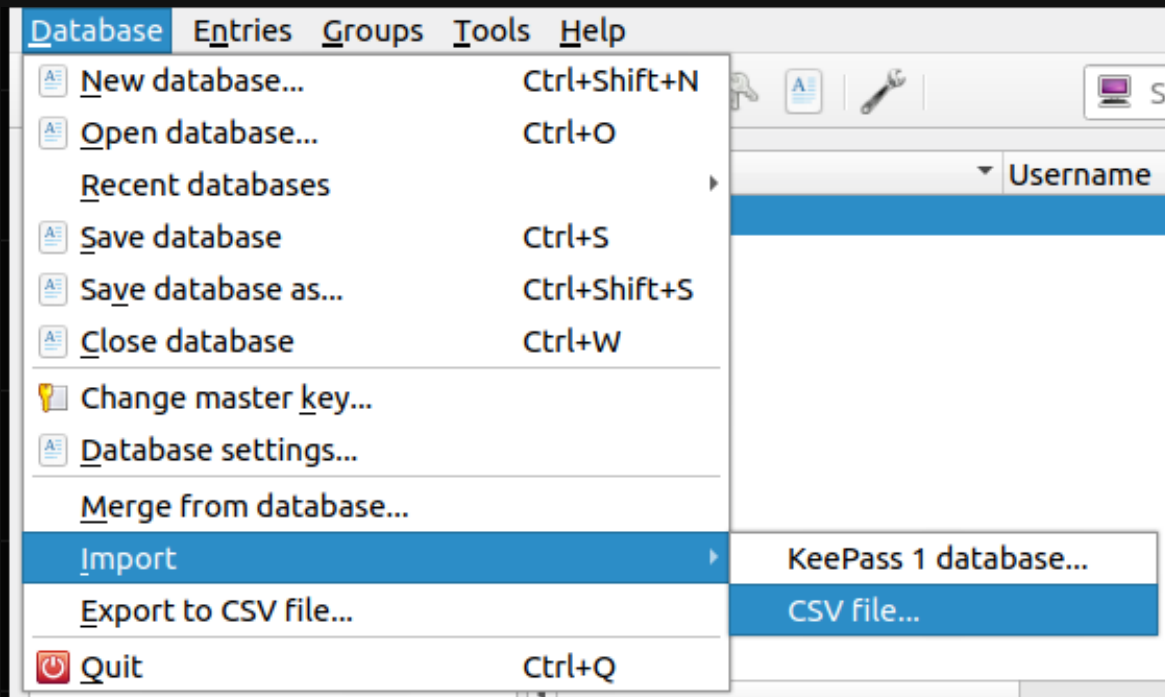
Remove

Open

Save

Novo registro

Importação de senhas



CTRL+SHIFT+V

Autotype

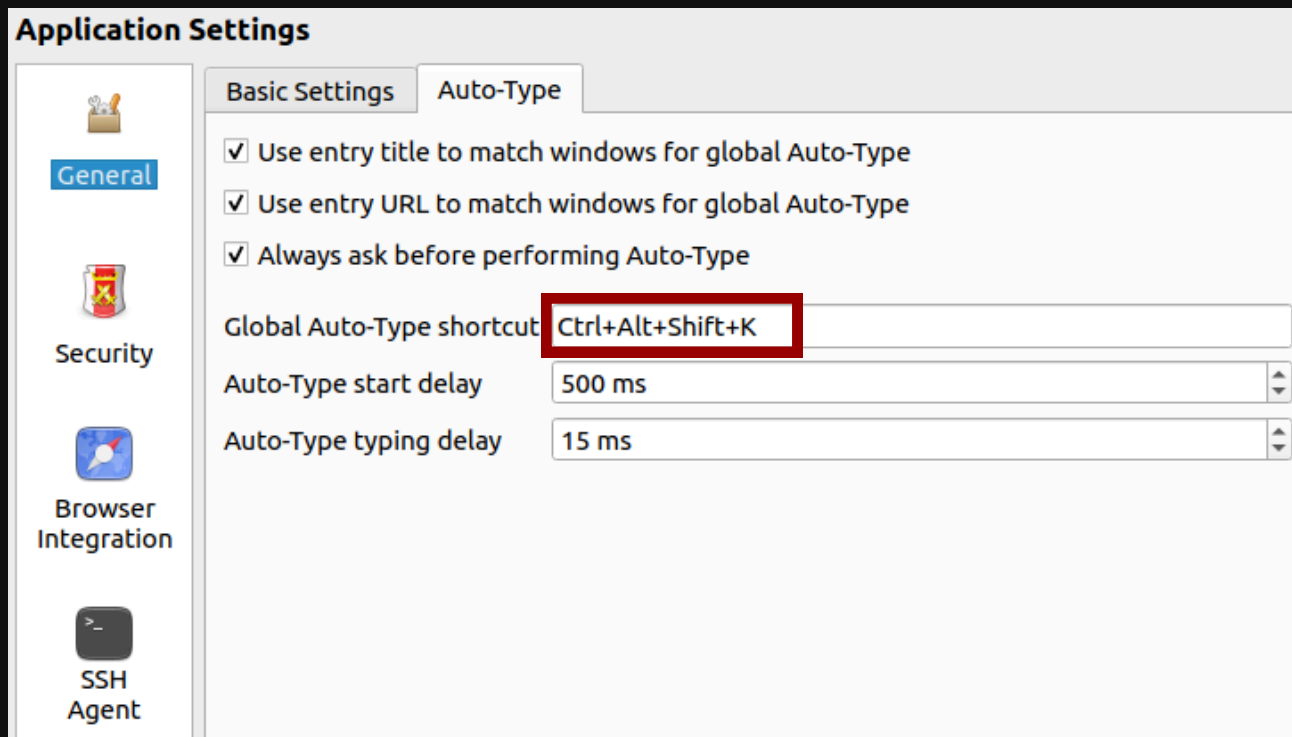
Tecle de atalho

Autotype

Tecle de atalho global

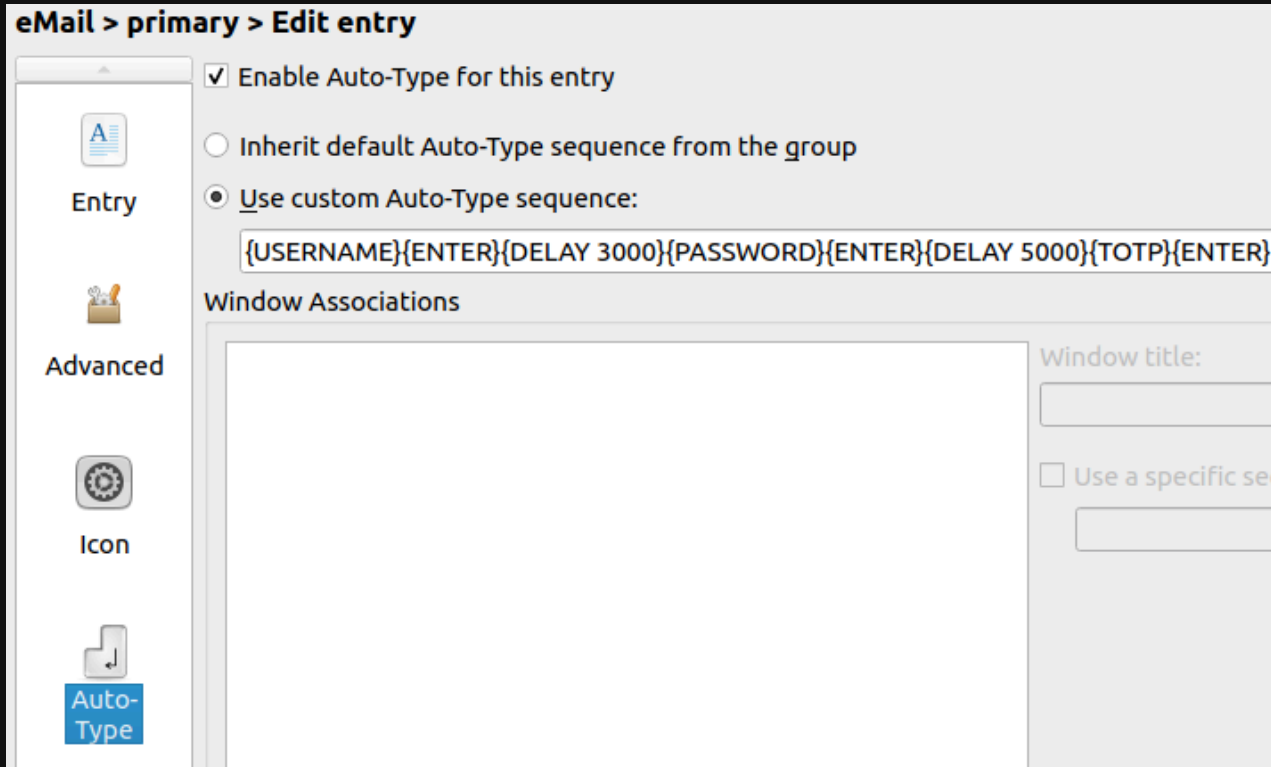
Autotype

Tecle de atalho global

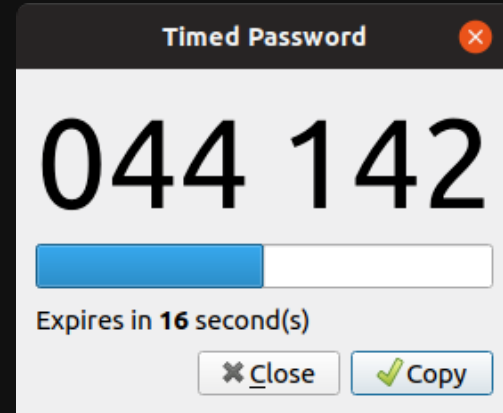
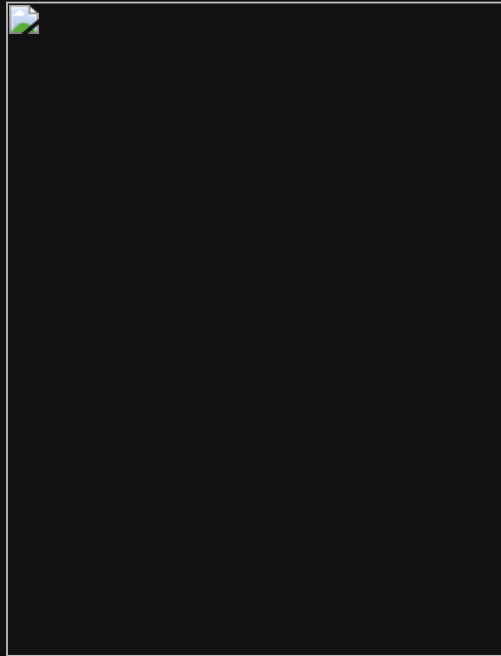


Autotype

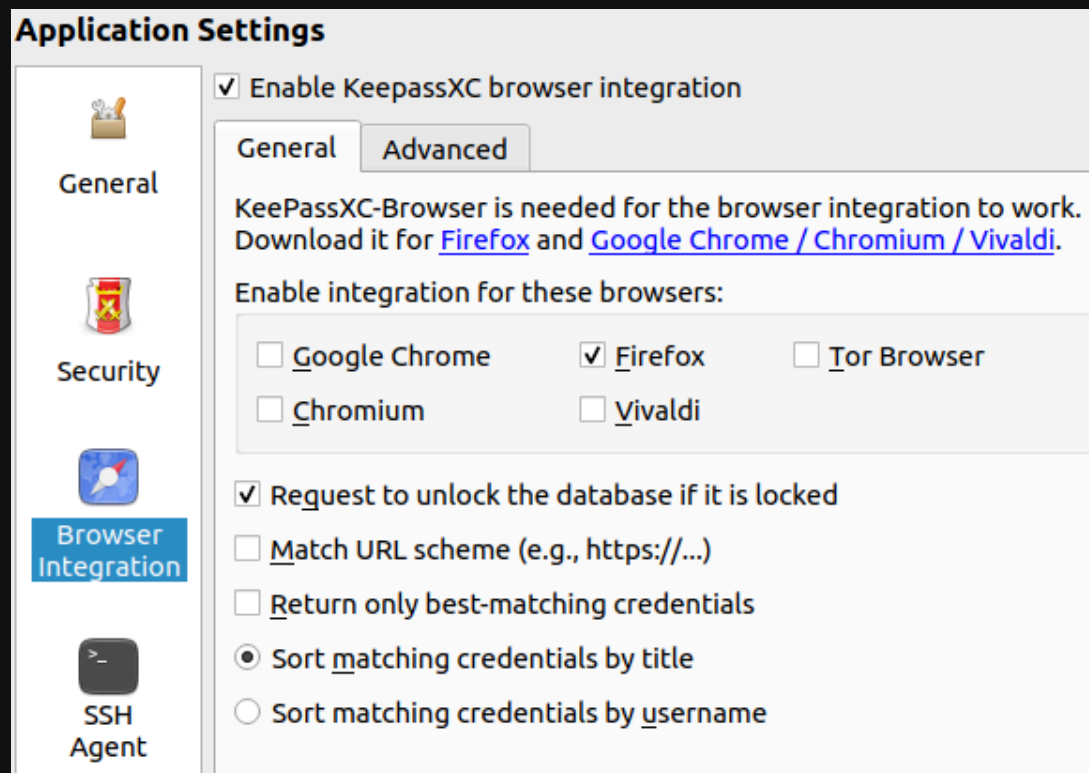
Sequência configurável



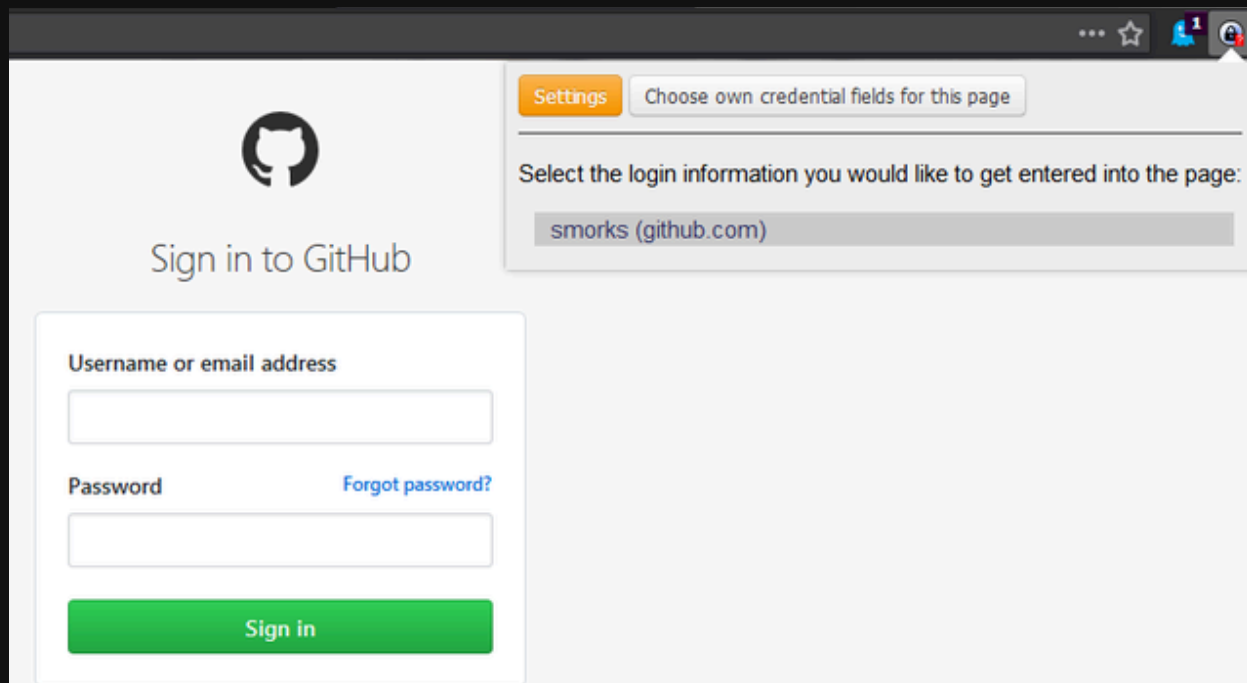
TOTP



Integrando com navegador



Integrando com navegador



Integrando com navegador

Nas configurações do navegador:

- Desabilitar autocomplete
- Desabilitar de salvar senhas

ssh-agent

1 - Criar uma senha para a chave privada e copiar

Raíz > Add entry

Entry

Advanced

Title: id_rsa

Username: user@email.com

Password:

Repeat:

URL:

☐ Expires 04/12/2018 23:32

☒ Notes

Presets

ssh-agent

2 - Gerar uma chave SSH com a senha copiada

```
~$ ssh-keygen -t rsa -b 4096 -o -f id_rsa -C user@email.com
Generating public/private rsa key pair.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in id_rsa.
Your public key has been saved in id_rsa.pub.
The key fingerprint is:
SHA256:/0AquhdSloVxKketevMFRknU+UgniQI40xWzZ0v2HHg user@email.com
The key's randomart image is:
+---[RSA 4096]-----+
|  .*00*++ 0      |
| 00.=00* *  .    |
| ++ 0* . =       |
| 0. += 0 . .     |
| .++E.S..        |
| .0++ . +.       |
|  0++..0         |
|   .... 0        |
|  00 .           |
+---[SHA256]-----+
```

ssh-agent

2 - Anexar o arquivo id_rsa no KeePass

Raiz > Add entry

Advanced

Icon

Auto-Type

Additional attributes

Add

Remove

Edit Name

☒ Protect

Reveal

Attachments

Name	Size
id_rsa	3,35 KiB

Add

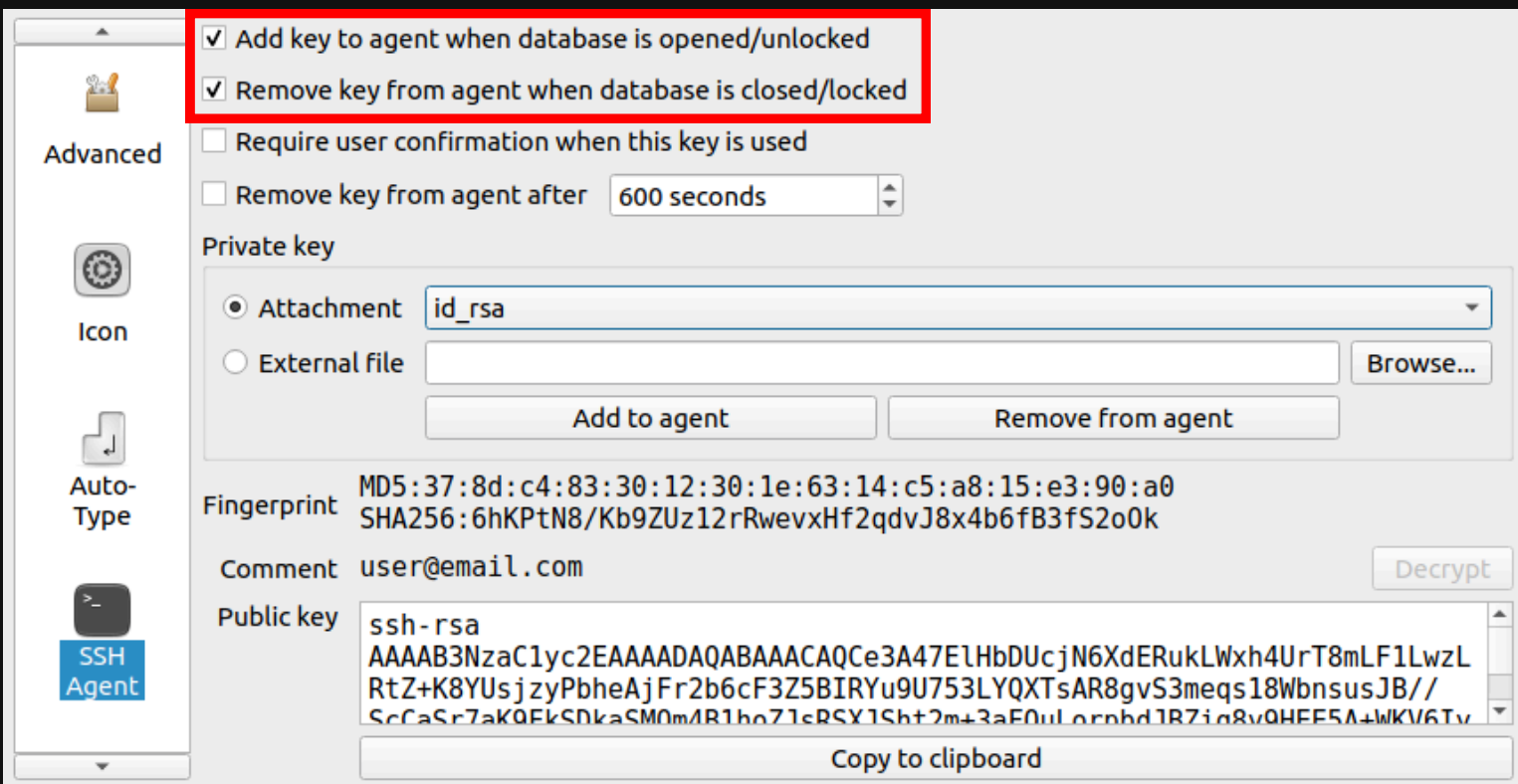
Remove

Open

Save

ssh-agent

3 - Informar onde está a chave privada e utilizar a pública



ssh-agent

3 - Informar onde está a chave privada e utilizar a pública

```
~$ ssh-add -l
4096 SHA256:6hKPtN8/Kb9ZUz12rRwevxHf2qdvJ8x4b6fB3fS2o0k user@email.com (RSA)
~$ git clone git@github.com:vitormattos/crack-password-calc.git
Cloning into 'crack-password-calc'...
remote: Enumerating objects: 67, done.
remote: Counting objects: 100% (67/67), done.
remote: Compressing objects: 100% (56/56), done.
remote: Total 67 (delta 23), reused 0 (delta 0), pack-reused 0
Receiving objects: 100% (67/67), 26.59 KiB | 41.00 KiB/s, done.
Resolving deltas: 100% (23/23), done.
```

Temas

1 - Instalar o **qt5ct**

```
sudo apt install qt5ct
```

2 - Exportar a seguinte variável:

OBS: pode colocar no arquivo ~/.profile

```
export QT_QPA_PLATFORMTHEME="qt5ct"
```

3 - Execute o programa **qt5ct** e escolha um tema

https://wiki.archlinux.org/index.php/qt#Configuration_of_Qt5_apps_under_environments_other_than_KDE_Plasma

PHP

Packagist *The PHP Package Repository*

[Browse](#)

[Submit](#)



keepass

Packagist is the main Composer repository. It aggregates public PHP packages installable with Composer.

keepassphp/keepassphp

KeePass password manager in PHP

PHP ↓ 128

★ 53

xp-forge/keepass

KeePass databases

PHP ↓ 1 555

★ 1

pbergman/keepass

a keepass lib for php

PHP ↓ 4

★ 7

keepassphp/keepassphp-ui

User Interface for KeePassPHP

PHP ↓ 10

★ 21

Referências

<https://keepassxc.org/>

<https://keepass.info/>

<https://wpenigne.com/unmasked/>

https://en.wikipedia.org/wiki/List_of_data_breaches

<https://github.com/hashcat/hashcat>

https://php.net/password_hash

The life



That's all Folks!

Obrigado!

Podem fazer perguntas
durante o evento

Redes sociais:
(VitorMattos ou VitorMattosRJ)

